

CISM Domain 2B — Information Security Risk Response: Exam Essentials

Second half of Domain 2 (Risk Management, 20% of the exam). Covers risk treatment/response options (2B1), risk & control ownership (2B2), and risk monitoring & reporting (2B3).

The Cost/Control Balance (2B1)

- Control costs RISE with level of control; cost of losses DROPS. Aim for the **optimal point**: risk reduced to an acceptable level (aligned with risk appetite) **without overspending**. Beyond a point, extra controls are disproportionately expensive.
- Risk can never be eliminated** — “zero risk” answers are always wrong. Objective: **residual risk** ≤ acceptable risk threshold.
- Risk acceptance should not exceed risk appetite and must NEVER exceed risk capacity.**

Risk Treatment — the four responses

Response	What it means / when to use
Avoid	Change business practices to eliminate the risk entirely — can cost business opportunities
Mitigate	Apply security controls to reduce probability and/or magnitude (e.g., adding controls for a new process)
Transfer	Shift some impact to another entity — cyber insurance is the classic example
Accept	Consciously continue as normal — when risk is within tolerance or cost of mitigation > cost of impact; must be FORMALLY DOCUMENTED

Exam pattern: the security manager RECOMMENDS acceptance and **escalates to senior management for approval** — the security manager never accepts risk alone.

Risk Acceptance Framework

- Defines **when and how** risk can be accepted: approval processes, documentation requirements, reporting lines — a conscious, governed decision, never ad hoc.
- Final acceptance considers: cost/effectiveness of controls, acceptable impact, culture/maturity, regulatory requirements, risk appetite, uncertainty — plus **intangibles** (reputation, lost opportunity).
- Accepted risks must still be **monitored** for changed conditions.

Controls & Control Objectives

A **control** = any procedure, practice, policy, standard, or technology that regulates activity or behavior to reduce/eliminate risk.

Classification	Examples
Preventive	Access controls, authentication, awareness training, change management, firewalls, encryption, antimalware, physical security

Detective	Log monitoring, SIEM, trend analysis, security audits, video surveillance, motion detection
Corrective	Incident response planning, root-cause identification, backup/restore, patch management
Administrative	Policies/procedures: training, change management, audits, IR planning
Technical (logical)	Hardware/software: firewalls, encryption, SIEM, authentication, backups, patching
Physical	Things you can touch: locks, video surveillance, motion detection

- Assess effectiveness via control self-assessments, independent audits, vulnerability scans.
- Controls must be **technically effective, cost-effective, AND support business objectives** — over-controlling wastes money, under-controlling leaves exposure.

Compliance & Cost-Benefit

- ISACA: evaluating consequences of noncompliance is a **business decision** — noncompliance may be warranted if enforcement is rare or fines cost less than compliance. **EXCEPTIONS: human safety and user privacy** — ethics and reputation take precedence.
- Mandatory/prescriptive regulations (e.g., GDPR) **cannot be negotiated or accepted as risk** — must chart a course to compliance.
- **Business case** = persuasive justification in BUSINESS terms (ROI, strategic alignment, fines avoided) — not a technical explanation. “New firewall reduces breach risk by X%, saving \$Y in fines” beats “old one is end-of-life.”
- Never spend more on a control than the potential loss — if control cost > benefit, accept (within tolerance), transfer, or use a compensating control.

Risk & Control Ownership (2B2)

Risk Owner	Control Owner
ACCOUNTABLE for the risk outcome	RESPONSIBLE for operating/overseeing the specific control
Senior executive/manager whose area is most affected; must have authority to decide treatment	Authority + accountability for control decisions; often the SAME person as risk owner for critical controls
Decides responses, allocates resources, accepts residual risk, monitors and reports	Ensures control is designed, documented, tested; monitors performance, takes corrective action
—	IT staff who implement/maintain = custodians/stewards, NOT owners

RESPONSIBILITY can be delegated; ACCOUNTABILITY cannot (same rule as Domain 1).

Data/asset owner = the person with decision-making power in the department deriving the most benefit — e.g., customer data in the sales CRM is owned by the **sales department manager**, not the CIO, DBA, or security manager (classic exam question).

Risk Monitoring & KRIs (2B3)

- **KRIs = forward-looking** metrics that act as **EARLY WARNING** signals of rising risk exposure (e.g., phishing emails blocked, patch latency, downtime frequency).
- **KRI vs KPI:** KRI = early warning that risk is increasing (predictive); KPI = how well the program performs (backward-looking).
- **KRI selection criteria:** impact, effort to implement/measure/report, reliability (correlates with the real risk), sensitivity (detects change early), stakeholder relevance, balance (leading + lagging + trend indicators).
- KRIs should align with business goals and have **thresholds that trigger escalation**.
- **PRIMARY objective of monitoring KRIs: identify CHANGE in security exposures** (exam answer — not cost reduction or compliance).

Risk Reporting & Communication

- **Triggering events** for immediate reporting/reassessment: significant incidents, environment changes, business/strategy changes, new regulations.
- Reports need defined channels, format, frequency; **tailor medium, detail, and cadence to the audience** (technical vs executive) — any exam answer about communication should be audience-tailored.
- **Two-way communication:** leadership provides updates; employees report observed risks/incidents. Risk management is EVERYONE's responsibility.
- Security incidents may require a **special report to senior management** (incident, impact, mitigation steps).

Documentation

- **Risk management policy** should cover: objectives/rationale, scope & charter, roles & responsibilities, process steps, response guidance, documentation requirements, communication/training, timelines, reporting/escalation.
- Supporting docs: **risk register** (living list of risks, owners, status), risk management framework (governance + risk appetite), assessment reports, communication plan, risk treatment plans.
- Document risk acceptance decisions to demonstrate **due diligence**; version control with classification level, revision date and number.
- **Board approval of the risk management policy** is key to gaining support from all stakeholders.

Quick Self-Check (from the handout)

1. Implementing additional controls for a new process = ? → **Mitigating the risk**
2. Owner of customer data in the sales CRM? → **Sales department manager**
3. Most important objective of monitoring KRIs? → **Identify change in security exposures**

Last-Minute Memory Hooks

- Acceptance $\leq$ appetite, and never $>$ capacity
- Zero risk is impossible — goal is residual risk $\leq$ acceptable level
- Security manager recommends; senior management accepts
- Asset owner = business department that benefits most, not IT
- KRI = early warning (forward); KPI = performance (backward)

- Safety and privacy are never acceptable noncompliance trade-offs
- Business case speaks money and strategy, not technology